

Использование Burp Suite для анализа безопасности веб-приложений

Работу выполнил:
Смольняков Данил Евгеньевич
НБИбд-02-24

Российский университет дружбы народов, Москва,
Россия

Цель работы

- Освоение инструментария Burp Suite для анализа безопасности веб-приложений
- Получение практических навыков перехвата и модификации HTTP-трафика
- Выполнение атаки перебором параметров с использованием Intruder

Техническое обеспечение

- Intel Core i3-550 3.2 GHz,
- 4 GB оперативной памяти,
- 20 GB свободного места на жёстком диске;
- ОС Linux Gentoo
- VirtualBox верс. 6.1 или старше

Запуск Burp Suite

- Запуск приложения Burp Suite в ОС Kali Linux

```
(kali㉿kali)-[~]  
$ burpsuite  
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to J  
AVA_CMD = java  
Your JRE appears to be version 21.0.9 from Debian  
Burp has not been fully tested on this platform and you may experience proble  
ms.  
□
```

Настройка Proxu для перехвата трафика

- Настройка слушателя на порту 8080 для перехвата HTTP-трафика

?

Proxy listeners

⚙

Burp Proxy uses listeners to receive incoming HTTP requests from your browser. You will need to configure your browser to use one of the listeners as its proxy server.

Add

Edit

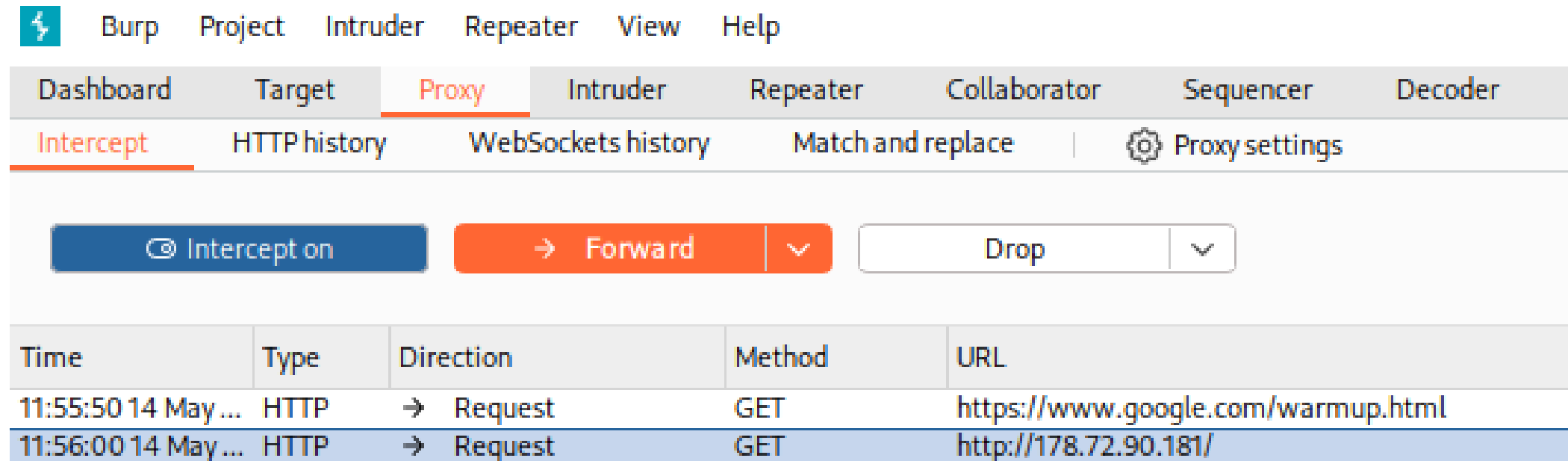
Remove

Running	Interface	Invisible	Redirect	Certificate	TLS Protocols	Sn
☒	127.0.0.1:8080			Per-host	Default	

Each installation of Burp generates its own CA certificate that Proxy listeners can use when negotiating TLS connections. You can import or export this certificate for use in oth

Перехват HTTP-запроса

- Перехват запроса к целевому веб-серверу



The screenshot displays the Burp Suite application interface. At the top, the menu bar includes 'Burp', 'Project', 'Intruder', 'Repeater', 'View', and 'Help'. Below this, the main navigation bar features tabs for 'Dashboard', 'Target', 'Proxy' (which is selected and highlighted in red), 'Intruder', 'Repeater', 'Collaborator', 'Sequencer', and 'Decoder'. Under the 'Proxy' tab, there are sub-options: 'Intercept' (highlighted with a red underline), 'HTTP history', 'WebSockets history', 'Match and replace', and 'Proxy settings' (indicated by a gear icon). Below the navigation bar, there are three main action buttons: 'Intercept on' (blue), 'Forward' (orange), and 'Drop' (white). The bottom section of the interface contains a table with two rows of intercepted HTTP requests.

Time	Type	Direction	Method	URL
11:55:50 14 May ...	HTTP	→ Request	GET	https://www.google.com/warmup.html
11:56:00 14 May ...	HTTP	→ Request	GET	http://178.72.90.181/

Настройка Intruder для атаки перебором

- Отправка запроса в Intruder и настройка параметров перебора

```
1 GET / HTTP/1.1
2 Host: 178.72.90.181
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
```

Результаты атаки Intruder

- Запуск атаки и анализ результатов

Заключение

- В ходе выполнения пятого этапа проектной работы был освоен инструментарий Burp Suite.
- Выполнена атака перебором пароля с помощью Intruder.
- Проанализированы результаты атаки (различия в длине ответа, статус-коды).